

관리자 카카오 인증 API 계약 (제안) — 김지민(admin-web) 합의용

- 일자: 2026-06-10
- 작성: 이승욱(service-user BE)
- 대상 합의자: 김지민(admin-web FE)
- 상태: 제안 — FE와 응답 형태 확정 후 service-user에 구현(task 3)
- 기준: 기존 사용자 로그인(`POST /api/v1/auth/kakao`, `LoginResponse`)과 일관성 유지. 단일 DB:service-user가 유일한 JWT 발급자(RS256).

1. 엔드포인트

`POST /api/v1/admin/auth/kakao` (permitAll - 인증 전 진입)

- 흐름: 카카오 access token 검증(`KakaoOAuthClient`) → 회원 조회(`members.kakao_id`) → 관리자 자격 검증(`admin_users` / `VerifyAdminRole`, task 1) → ADMIN 스코프 JWT 발급(`JwtProvider`).
- 관리자가 아니면 토큰을 발급하지 않고 인가 오류를 반환.

2. 요청 (사용자 로그인과 동일 형태)

```
{ "kakaoAccessToken": "<카카오 SDK가 발급한 access token>" }
```

- 필드: `kakaoAccessToken` (string, 필수). 기존 `LoginRequest`와 동일 — FE가 카카오 SDK로 받은 토큰을 그대로 전달.

3. 성공 응답 (200) — 공통 envelope `ApiResponse<AdminLoginResponse>`

```
{
  "success": true,
  "data": {
    "accessToken": "<JWT, role=ADMIN>",
    "refreshToken": "<JWT refresh>",
    "admin": {
      "memberId": 12,
      "nickname": "운영자",
      "role": "ADMIN",
      "adminRole": "SUPER_ADMIN",
      "status": "ACTIVE"
    }
  },
  "error": null
}
```

- **accessToken / refreshToken**: 사용자 로그인과 동일하게 body로 전달(admin-web가 저장). access token claim의 **role=ADMIN**.
- **admin** 블록(사용자 **member** 요약과 대응, admin 전용 필드 추가):
 - **memberId** (Long) — 회원 PK
 - **nickname** (string)
 - **role** (string) — 항상 **ADMIN**
 - **adminRole** (string) — **OPERATOR** / **REVIEWER** / **CONTENT_CREATOR** / **SUPER_ADMIN** (admin-web 메뉴 권한 분기용 ← **FE가 가장 필요로 할 값**)
 - **status** (string) — **ACTIVE** 등

4. 오류 응답 (공통 envelope, **success:false**)

상황	HTTP	ErrorCode(안)	의미
카카오 토큰 무효/만료	401	(기존 카카오 인증 오류 코드 재 사용)	카카오 검증 실패
회원은 있으나 관리자 아님	403	ADMIN_USER_NOT_FOUND	admin_users 없음 → 관리자 로그인 거부
관리자 계정 비활성/정지	403	(admin status 오류 코드)	admin_users.status 비활성

```
{ "success": false, "data": null,
  "error": { "code": "ADMIN_USER_NOT_FOUND", "message": "관리자 권한이 없습니다." }
}
```

5. 합의 필요 포인트 (FE 확인 요청)

1. **응답 키 이름**: 사용자 로그인은 **member**, 관리자는 **admin**으로 구분 제안 — FE가 **member**로 통일하길 원하면 맞춤 가능.
2. **adminRole 노출 범위**: 단일 역할 문자열로 충분한지, 아니면 권한 목록(향후 다중 역할 대비 배열)이 필요한지.
3. **refreshToken 전달 방식**: 사용자 앱은 body→SecureStorage. admin-web(브라우저)도 body로 받을지, HttpOnly 쿠키를 원할지(웹 보안상 쿠키 선호 가능).
4. **권한 부족(403) 처리 UX**: FE가 별도 안내 화면을 띄울지 → ErrorCode/message 문구 합의.
5. **토큰 만료**: admin access token 만료를 사용자와 동일(30분)로 둘지.

6. 비교

- 카카오 검증·JWT 발급은 service-user의 **KakaoOAuthClient/AuthService/JwtProvider** 재사용(신규 외부 연동 없음).
- 관리자 자격 검증은 task 1(VerifyAdminRole RestClient → admin-server)에 의존. task 1-dev 시드(task 4) 완료 후 task 3에서 본 계약대로 구현.
- 콘텐츠/AI 서비스는 **/api/v1/admin/**** 차단(transition-status §1). admin 인증 엔드포인트는 JWT 발급 권한이 있는 service-user에만 둔다.

